

A blue square with rounded corners containing the white text "S2".

# Sandbox Auditor

Руководство по эксплуатации

Автономная compliance-платформа для SOC 2 Type II

Версия 10.0

770 тестов ✓

2026-05-24

Полное руководство: архитектура, установка, все функции системы, API-справочник, интеграции, мониторинг и сравнение с Vanta.



# Sandbox Auditor — Руководство по эксплуатации

> Версия: 10.0 (Фаза 10, Block C)

> Тестов: 770 / 770 ☐

> Дата: 2026-05-24

## Оглавление

1. [Что это такое и для кого](#1-что-это-такое-и-для-кого)
2. [Что можно делать с этой системой](#2-что-можно-делать-с-этой-системой)
3. [Архитектура — из чего состоит система](#3-архитектура-из-чего-состоит-система)
4. [Модули — подробное описание каждого](#4-модули-подробное-описание-каждого)
5. [Пользовательский интерфейс — все экраны](#5-пользовательский-интерфейс-все-экраны)
6. [API — полный список эндпоинтов](#6-api-полный-список-эндпоинтов)
7. [Установка и запуск](#7-установка-и-запуск)
8. [Конфигурация — все переменные окружения](#8-конфигурация-все-переменные-окружения)
9. [Пользователи и роли](#9-пользователи-и-роли)
10. [Агенты — как запускать и что делают](#10-агенты-как-запускать-и-что-делают)
11. [Сравнение с Vanta](#11-сравнение-с-vanta)
12. [Мониторинг и алерты](#12-мониторинг-и-алерты)
13. [База данных и хранение данных](#13-база-данных-и-хранение-данных)
14. [Интеграции с внешними системами](#14-интеграции-с-внешними-системами)
15. [Устранение неполадок](#15-устранение-неполадок)
16. [Глоссарий](#16-глоссарий)

## 1. Что это такое и для кого

### Простыми словами

Представьте, что ваша компания хочет получить сертификат SOC 2 — это международный стандарт безопасности, который проверяет: правильно ли вы храните данные клиентов, защищены ли ваши системы, соблюдаете ли вы правила доступа к информации.

Обычно подготовка к SOC 2 аудиту занимает 6–12 месяцев и требует найма специального аудитора за \$50 000–\$200 000. Большая часть работы — монотонный сбор доказательств: «покажите, что MFA включена», «покажите, что уволенные сотрудники деактивированы», «покажите журналы доступа».

Sandbox Auditor автоматизирует весь этот процесс:

- Сам подключается к AWS, GitHub, Okta, Jira и другим системам
- Сам собирает доказательства по всем 33 контролям SOC 2
- Сам оценивает: каждый контроль PASS (выполнен), FAIL (нарушен) или NEEDS\_REVIEW (нужен человек)

- Сам создаёт Jira-тикеты на исправление найденных нарушений
- Сам генерирует черновики политик безопасности через AI
- Ведёт полную историю изменений — можно «перемотать» назад и посмотреть состояние на любую дату

Для кого

| Роль                                      | Что делает в системе                                                        |
|-------------------------------------------|-----------------------------------------------------------------------------|
| CISO / Head of Security                   | Видит общую картину: какой процент контролей выполнен, какие риски критичны |
| Compliance Officer                        | Управляет политиками, аттестациями, следит за lifecycle документов          |
| DevOps / IT Admin                         | Запускает сканеры, настраивает интеграции, читает технические отчёты        |
| Внешний аудитор                           | Входит через Auditor Portal, смотрит доказательства, оставляет комментарии  |
| Сотрудник                                 | Проходит обучение по безопасности, подписывает политики                     |
| Домохозяйка, случайно открывшая dashboard | Видит большой процент (82%) и цветные статусы — зелёный/красный/жёлтый      |

2. Что можно делать с этой системой

Это полный список функций системы. Ни одна не пропущена.

2.1 Автоматический сбор доказательств

- Сканирование AWS: S3 buckets (шифрование, публичный доступ), IAM пользователи (MFA, неактивные), EC2 (открытые порты, security groups), RDS (шифрование, публичный доступ), CloudTrail (логирование включено?)
- Сканирование GitHub: branch protection на main, secret scanning включён, PR review обязателен, прямые коммиты в main
- Сканирование Okta: уволенные сотрудники с активными аккаунтами, dormant-аккаунты (не заходили >90 дней), пользователи без MFA, SUPER\_ADMIN роли
- 160 дополнительных проверок через Prowler (отраслевой инструмент безопасности)
- Сканирование уязвимостей с CVE-оценками и SLA по срокам устранения

2.2 Оценка соответствия

- Автоматическая оценка всех 33 контролей AICPA SOC 2 TSC 2017
- Детерминистический движок: FAIL-доказательство всегда даёт FAIL (не зависит от AI)
- Взвешенная оценка: критичные контроли (CC6.1 MFA) имеют больший вес
- Объяснение каждого FAIL: почему, какая цепочка зависимостей, какие риски затронуты
- Маппинг на другие фреймворки: ISO 27001, NIST CSF, CIS Controls

2.3 Управление политиками

- AI-генерация черновиков политик для 16 контролей (через Claude/Gemini)

- Полный lifecycle: черновик → на проверку → одобрен/отклонён → активен → истёк
- Версионирование: история всех версий каждой политики
- Разделение обязанностей (SoD): написал AI → проверяет человек → утверждает другой человек
- Push политик в GitHub репозиторий

## 2.4 Управление рисками

- Реестр рисков с оценкой  $\text{likelihood} \times \text{impact} = \text{risk score}$
- Автоматическое создание риска при FAIL-контроле
- Risk matrix — визуализация рисков по квадрантам
- Планы лечения рисков: mitigate / accept / transfer / avoid
- Связь рисков с контролями и активами

## 2.5 Remediation (исправление нарушений)

- Автоматическое создание Jira-тикетов при FAIL
- Idempotent создание: один и тот же FAIL не создаёт дублирующиеся тикеты
- Slack-кнопки для немедленных действий: отозвать IAM-доступ, применить patch — прямо из Slack
- Gap Analysis: AI-анализ что именно нужно сделать для перехода FAIL → PASS
- Отслеживание статуса remediation: открыт/в работе/закрит

## 2.6 Управление людьми

- Access Review: регулярный обзор прав доступа, решения approve/revoke с аудит-следом
- Security Training: встроенная LMS с 5 курсами, сертификаты, отслеживание просроченных
- Background Checks: управление проверками сотрудников через Checkr API
- HR Audit: синхронизация с Okta, выявление уволенных с активным доступом
- Опросы по знанию политик: автоматические опросы с результатами

## 2.7 Управление вендорами

- Реестр вендоров с уровнями риска: critical / high / medium / low
- Автоматическая оценка риска вендора по заданным критериям
- Анкеты для вендоров (SIG Lite, CAIQ Lite форматы)
- Отслеживание DPA (Data Processing Agreement) — подписан ли
- Управление субпроцессорами (цепочка вендоров)
- DocuSign-интеграция для подписания договоров

## 2.8 Pentest Management

- Загрузка отчётов о пентестах
- Трекинг findings (уязвимостей из пентеста) с SLA по устранению
- Статусы: open / in\_progress / fixed / accepted\_risk
- История пентестов по годам

## 2.9 Аудиторский портал

- Отдельный защищённый вход для внешних аудиторов

- Просмотр доказательств с фильтрацией по контролю
- Оставление комментариев к контролям
- Сводка готовности к аудиту (audit readiness summary)

## 2.10 Trust Center

- Публичная страница (без логина) для клиентов и партнёров
- Показывает общий % соответствия, активные сертификации
- NDA-gate: полные детали только после подписания NDA
- Запрос доступа к полному отчёту через форму

## 2.11 Compliance as Code

- YAML-декларации контролей с автоматическими проверками
- Запуск CaC-контролей: каждый контроль — это код с чёткими условиями PASS/FAIL
- Approval workflow: авто-исправимые контроли vs требующие человека
- SLA на исправление в спецификации

## 2.12 Time Machine

- Посмотреть состояние compliance на любую дату в прошлом
- «Машина времени»: как выглядел Dashboard 3 месяца назад?
- Сравнение двух моментов: что изменилось за последний квартал?
- Поиск регрессий: когда именно контроль перешёл из PASS в FAIL?

## 2.13 Event Sourcing и Audit Trail

- Полная история всех изменений в системе (append-only, нельзя удалить)
- Цепочка причинности: почему изменился контроль → какое событие это вызвало
- Replay: детерминистически воспроизвести любой момент истории
- Compliance Timeline: график % соответствия за любой период с любой детализацией

## 2.14 Compliance Graph

- Граф зависимостей: CC6.1 зависит от CC6.3 зависит от CC1.1
- Распространение риска: FAIL одного контроля влияет на смежные
- Визуализация: какие контроли связаны с данным вендором
- Поиск кратчайшего пути между двумя контролями
- Найти все контроли, затронутые конкретным риском

## 2.15 Asset Management

- Реестр IT-активов: устройства, облачные аккаунты, репозитории, базы данных, сотрудники
- Привязка контролей к активам: «CC6.1 применяется к этим 47 устройствам»
- Синхронизация из MDM систем (Jamf Pro, Microsoft Intune)
- Синхронизация из сканера (автоматическое обнаружение)
- Compliance posture по активу: какие контроли выполнены для этого устройства

## 2.16 Governance

- Граф полномочий: кто может одобрять что
- Аттестации с криптографической подписью (HMAC-SHA256)
- TTL на аттестации: истекает через X часов
- Отзыв аттестаций с аудит-следом
- Проверка покрытия аттестациями всех контролей

## 2.17 Chaos Engineering

- Намеренный ввод нарушений для проверки системы реакции
- Инъекция: отключить MFA, открыть порт, отозвать branch protection
- Измерение SLA реакции: через сколько минут система обнаружила нарушение?
- Восстановление исходного состояния одной кнопкой

## 2.18 Отчётность

- HTML-отчёт: красивый, с таблицами, grafana-скриншотами, подходит для отправки
- PDF-отчёт: для официального предоставления аудитору
- История отчётов: все когда-либо сгенерированные отчёты сохраняются
- Экспорт на любую дату

## 2.19 Мониторинг

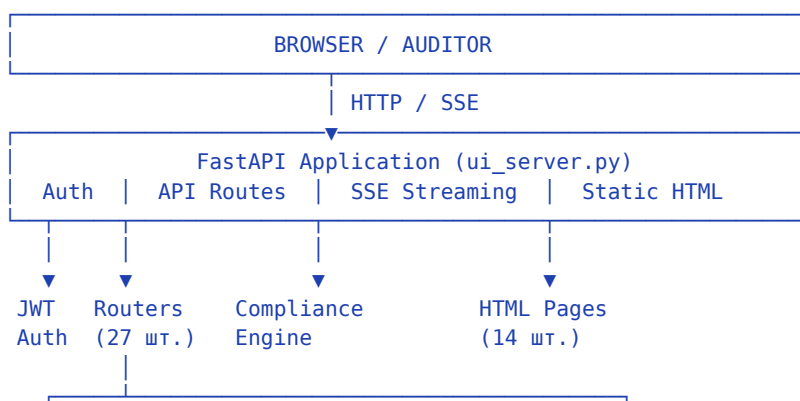
- Prometheus-метрики: количество запросов, latency, ошибки
- Grafana-дашборд: 9 панелей с реальными метриками
- Rate limiting: защита от перегрузки API (10 запросов/мин на login)
- Security headers на всех ответах

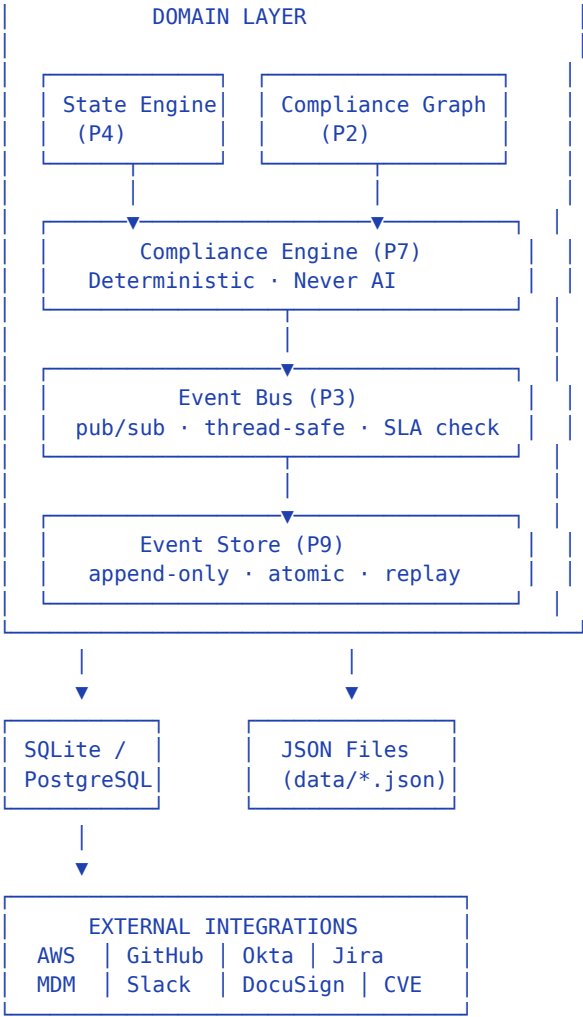
## 2.20 Webhooks и Real-time

- Получение событий от GitHub (push, PR, secret alert)
- Получение событий от Okta (пользователь деактивирован, роль изменена)
- Получение команд от Slack (кнопки подтверждения/отзыва доступа)
- Celery: тяжёлые задачи (полный аудит) выполняются в фоне, не блокируя UI

# 3. Архитектура — из чего состоит система

## Схема высокого уровня





Docker-сервисы

```
docker compose up -d → 6 сервисов

ui_server      :8080   главное приложение (FastAPI)
grafana        :3000   дашборды (логин: admin / soc2admin)
prometheus     :9090   сбор метрик (скрейпит ui_server каждые 15с)
redis          :6379   очередь задач Celery + кэш
celery         -      воркер для фоновых задач
localstack     :4566   эмулятор AWS (S3, IAM, EC2, RDS, CloudTrail)
```

Слой архитектуры

| Слой         | Что делает                            | Ключевые файлы                                                   |
|--------------|---------------------------------------|------------------------------------------------------------------|
| Presentation | HTML страницы, API эндпоинты          | ui/index.html, *_routes.py                                       |
| Application  | Бизнес-логика, оркестрация агентов    | ui_server.py, orchestrator.py                                    |
| Domain       | Compliance-логика, правила, онтология | compliance_engine.py, compliance_ontology.py, control_mapping.py |
| State        | Единый источник истины о состоянии    | compliance_state_engine.py, compliance_graph.py                  |
| Events       | Все изменения как события             | event_bus.py, event_sourcing.py                                  |

| Слой           | Что делает                       | Ключевые файлы                             |
|----------------|----------------------------------|--------------------------------------------|
| Infrastructure | DB, HTTP-клиенты, внешние API    | database.py, db_repository.py, *_client.py |
| AI Advisory    | Советы AI (не принимают решений) | ai_advisor.py, ai_decision_log.py          |

## Принципы которые нельзя нарушать

1. AI не принимает решений — только советует. Deterministic engine (`compliance_engine.py`) всегда главный.
2. Audit log неизменяем — записи в `AuditEvent` и `EventStore` никогда не удаляются.
3. Аттестации подписаны криптографически — их нельзя подделать без знания `SECRET_KEY`.
4. SoD — тот, кто написал политику, не может её сам одобрить.

## 4. Модули — подробное описание каждого

### 4.1 Ядро системы

#### `ui_server.py` — Главное приложение

Сердце системы. FastAPI-сервер который:

- Отдаёт HTML-страницы браузеру
- Предоставляет REST API для всех операций
- Управляет авторизацией через JWT-токены в Cookie
- Запускает агентов через SSE (Server-Sent Events) — результаты приходят в реальном времени
- Scheduled job: полный аудит каждый день в 03:00 UTC
- Prometheus-метрики на `/metrics`
- Rate limiting: 10 запросов в минуту на `/api/auth/login`

#### `auth.py` — Авторизация

JWT-токены хранятся в HTTP-only Cookie (защита от XSS). Роли:

- `admin` — полный доступ ко всему
- `auditor` — read-only + комментарии
- `reviewer` — может одобрять политики и access reviews
- `scanner` — может только запускать сканирование

Учётные записи по умолчанию (меняйте в `.env`):

```
admin@example.com / admin123
auditor@example.com / auditor123
```

#### `config.py` — Конфигурация

Единое место для всех настроек. Читает из `.env` файла или переменных окружения. Pydantic автоматически валидирует типы и наличие обязательных значений.

#### `database.py` — База данных

Поддерживает два режима:

- Dev: SQLite ([compliance.db](#) в папке проекта) — без установки чего-либо
- Prod: PostgreSQL — задать `DATABASE_URL=postgresql+asyncpg://...`

При отсутствии `DATABASE_URL` система работает через JSON-файлы в папке `data/`.

## 4.2 Агенты сбора доказательств

### `scanner.py` — AWS Scanner

Подключается к AWS (или LocalStack в dev-режиме) и проверяет:

| Проверка            | SOC 2 контроль | Что ищет                     |
|---------------------|----------------|------------------------------|
| S3 Public Access    | CC6.1          | Bucket публично доступен?    |
| S3 Encryption       | CC6.7          | Шифрование включено?         |
| IAM MFA             | CC6.1          | MFA у всех пользователей?    |
| IAM Inactive Users  | CC6.2          | Аккаунты > 90 дней без входа |
| EC2 Security Groups | CC6.6          | Открытые порты SSH/RDP/DB    |
| RDS Encryption      | CC6.7          | БД зашифрована?              |
| CloudTrail          | CC7.2          | Логирование включено?        |

Результат: файл `controls_map.json` с обновлёнными статусами.

### `prowler_runner.py` — Prowler Runner

Prowler — популярный open-source инструмент для 160+ проверок безопасности AWS. Запускается локально (требуется `pip install prowler`). Не работает внутри Docker (это норма для dev-режима).

Запуск:

```
python3 prowler_runner.py
```

### `github_agent.py` — GitHub Agent

Проверяет репозиторий на:

- Branch protection на `main` — PR обязателен?
- Secret scanning включён?
- Dependabot alerts активен?
- Прямые коммиты в `main` за последние 30 дней
- Открытые security issues

### `hr_agent.py` — HR Agent

Синхронизируется с Okta и проверяет:

- Уволенные сотрудники (из HR roster) с активными Okta аккаунтами
- Сотрудники без пройденного обязательного обучения
- Аккаунты без MFA
- Пользователи с привилегированными ролями без обоснования

### `mdm_agent.py` — MDM Agent

Инвентаризация устройств через Jamf Pro или Microsoft Intune:

- Список всех управляемых устройств

- Включён ли FileVault (шифрование диска)?
- Установлен ли EDR (endpoint security)?
- Актуальна ли ОС?

#### vendor\_risk\_agent.py — Vendor Risk Agent

Оценивает каждого вендора по критериям риска:

- Доступ к данным клиентов?
- Подписан ли DPA?
- Есть ли собственные сертификаты (SOC 2, ISO 27001)?
- Дата последней проверки

#### gap\_analysis\_agent.py — Gap Analysis Agent

AI-анализ: для каждого FAIL-контроля объясняет что именно нужно сделать для перехода в PASS. Использует AI только для генерации рекомендаций — сам статус AI не меняет.

### 4.3 Compliance-движок (ядро логики)

#### compliance\_engine.py — Deterministic Engine

Главный арбитр. Никогда не использует AI. Правила:

1. Есть хотя бы одно FAIL-доказательство → контроль FAIL
2. Все обязательные доказательства присутствуют и свежие → PASS
3. Иначе → NEEDS\_REVIEW (нужен человек)

Уверенность (confidence): 0.0 → 1.0. При FAIL с критичным доказательством = 1.0 (абсолютная уверенность).

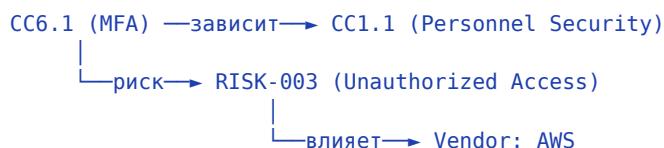
#### compliance\_state\_engine.py — State Engine (P4)

Единый источник истины о текущем состоянии всего compliance. Хранит кэш всех контролей. Умеет объяснить:

- Почему контроль FAIL → dependency chain → какие риски затронуты → когда SLA истекает
- Какой была история изменений
- Сколько всего Evidence, по категориям

#### compliance\_graph.py — Compliance Graph (P2)

Граф зависимостей между всеми сущностями системы:



BFS-обход для поиска всех затронутых контролей при изменении одного.

#### compliance\_ontology.py — Ontology (P8)

Machine-readable описание каждого из 33 контролей в YAML. Для каждого контроля:

- Какие доказательства нужны
- Зависимости от других контролей
- Вес риска (1-5)
- SLA на исправление (в часах)

- Маппинг на ISO 27001, NIST, CIS
- Можно ли исправить автоматически
- Кто владелец (роль)

event\_bus.py — Event Bus (P3)

Внутренняя шина событий. Когда что-то меняется → публикуется событие → подписчики реагируют:

| Событие                | Кто публикует     | Кто слушает             |
|------------------------|-------------------|-------------------------|
| EVIDENCE_ADDED         | evidence_client   | SLA checker, AuditTrail |
| CONTROL_STATUS_CHANGED | compliance_engine | Risk escalation, Slack  |
| RISK_ESCALATED         | risk module       | Slack (critical only)   |
| POLICY_APPROVED        | policy_lifecycle  | AuditTrail, governance  |
| SLA_BREACH             | event_bus внутри  | AIDecisionLogger        |

event\_sourcing.py — Event Store (P9)

Append-only хранилище всех событий. Каждое событие имеет:

- sequence\_number — монотонно возрастающий номер
- causation\_id — какое событие вызвало это
- correlation\_id — группировка событий одной транзакции

Позволяет детерминистически воспроизвести любой момент истории.

4.4 AI-слои (только advisory)

ai\_advisor.py — AI Advisor

Генерирует рекомендации по контролям и remediation. Важно: любой ответ AI содержит:

```
is_advisory_only = True
disclaimer = "AI suggestion – requires human review"
```

AI не может изменить статус контроля напрямую.

ai\_decision\_log.py — AI Decision Log

Каждое обращение к AI записывается:

- Что спросили
- Что AI ответил
- Уверенность AI (0-1)
- Кто запросил
- Было ли предложение принято человеком

Это explainability layer — аудитор может проверить каждое AI-решение.

policy\_agent.py — Policy Generator

Генерирует черновики политик безопасности через LLM (Claude или Gemini через OpenRouter). Поддерживает 16 типов политик: Access Control, Change Management, Incident Response и т.д. После генерации черновик обязательно проходит human review.

## 4.5 Persistence (хранение данных)

### models.py — ORM модели

SQLAlchemy-модели для всех основных сущностей. Все поля с типами — нет "magic strings".

### db\_repository.py — Repository Pattern

Каждая сущность имеет свой репозиторий с методами `get`, `create`, `update`, `delete`. Бизнес-логика не знает о деталях хранения.

### event\_store (часть event\_sourcing.py)

Отдельное хранилище событий. В dev-режиме: `data/event_store.json`. Атомарная запись через `os.replace()` + `fcntl.flock`. Нельзя удалить запись — только добавить.

## 4.6 Governance

### governance\_graph.py — Governance Graph (P6)

Формализует кто что может одобрять:

- `ciso` — может одобрять политики и принимать риски
- `compliance_officer` — может аттестовать контроли
- `manager` — может одобрять access reviews
- Делегирование: `manager` → `compliance_officer`

Аттестации подписаны HMAC-SHA256 с `SECRET_KEY` — их нельзя подделать. TTL: истекают через N часов.

## 5. Пользовательский интерфейс — все экраны

| Адрес              | Страница                 | Доступ                 | Что показывает                                                                                            |
|--------------------|--------------------------|------------------------|-----------------------------------------------------------------------------------------------------------|
| /                  | Dashboard                | Все пользователи       | Общий % соответствия, статусы 33 контролей, бенто-сетка с ключевыми метриками, список агентов для запуска |
| /trust             | Trust Center             | Публичный (без логина) | % соответствия для клиентов, активные сертификации, форма запроса NDA                                     |
| /training          | Security Training        | Все пользователи       | 5 обязательных курсов, прогресс, сертификаты                                                              |
| /background-checks | Background Checks        | Admin                  | Список проверок сотрудников, статусы, сроки                                                               |
| /vulnerabilities   | Vulnerability Management | Все пользователи       | CVE-уязвимости, SLA, CVSS-оценки                                                                          |
| /pentests          | Pentest Reports          | Admin                  | История пентестов, findings, статусы устранения                                                           |

| Адрес           | Страница       | Доступ           | Что показывает                                 |
|-----------------|----------------|------------------|------------------------------------------------|
| /risk-register  | Risk Register  | Все пользователи | Risk matrix, список рисков, планы лечения      |
| /audit-timeline | Audit Timeline | Admin            | Milestones аудита, wizard подготовки           |
| /questionnaires | Questionnaires | Все пользователи | Анкеты для вендоров (SIG Lite, CAIQ)           |
| /access-review  | Access Review  | Reviewer / Admin | Список доступов, решения approve/revoke        |
| /auditor-portal | Auditor Portal | Auditor          | Доказательства, комментарии, сводка готовности |
| /login          | Login          | Публичный        | Форма входа                                    |

## Навигация Dashboard

Dashboard разбит на разделы в боковом меню:

- Dashboard — главный экран
- Controls — список 33 контролей
- Agents — запуск сканеров
- Risk Register — реестр рисков
- Compliance Graph — граф зависимостей
- Assets — IT активы
- Events — лента событий
- State — compliance state engine
- Governance — аттестации
- Replay — машина времени
- Reports — отчёты

## 6. API — полный список эндпоинтов

### Аутентификация

- POST /api/auth/login — вход (email + password)
- POST /api/auth/logout — выход
- GET /api/auth/me — текущий пользователь

### Контроли и доказательства

- GET /api/controls — список всех 33 контролей
- GET /api/evidence?control\_id=CC6.1 — доказательства для контроля
- GET /api/running — список запущенных агентов
- POST /api/run/{agent\_name} — запустить агент (SSE stream)

### Compliance Engine

- GET /api/engine/evaluate/{control\_id} — оценить контроль
- GET /api/engine/score — общий score
- GET /api/engine/missing-evidence — что не хватает

### State Engine (P4)

```

GET /api/state/control/{control_id} – полный state контроля
GET /api/state/posture – общая compliance posture
GET /api/state/explain/{control_id} – почему FAIL + цепочка
POST /api/state/recalculate – пересчитать state
GET /api/state/snapshot – снимок всего state
POST /api/state/restore – восстановить из снимка

```

## Compliance Graph (P2)

```

GET /api/graph/control/{control_id} – контекст контроля в графе
GET /api/graph/propagate/risk/{risk_id} – распространение риска
GET /api/graph/path?from=CC6.1&to=CC1.1 – путь между контролями
GET /api/graph/vendor/{vendor_id}/controls – контроли для вендора
GET /api/graph/summary – сводка по графу
POST /api/graph/rebuild – пересобрать граф

```

## Events (P3)

```

GET /api/events – история событий (фильтры: entity_id, type, severity)
GET /api/events/stats – статистика за 24h / 7d / 30d
POST /api/events/replay – replay событий из DB
GET /api/events/types – список типов событий
GET /api/events/{event_id} – событие по ID
DELETE /api/events/history – очистить историю (только dev)

```

## Replay / Event Sourcing (P9)

```

GET /api/replay/snapshot – снимок на дату (?at=2026-01-15T10:00:00Z)
GET /api/replay/control/{control_id} – история контроля
GET /api/replay/timeline – timeline (?from_dt=...&to_dt=...&resolution=day)
GET /api/replay/diff – diff между двумя датами
GET /api/replay/regression/{id} – когда контроль перешёл PASS-FAIL
GET /api/replay/causation/{event_id} – цепочка причинности
GET /api/replay/store/stats – статистика EventStore

```

## Assets (P5)

```

GET /api/assets – список активов
POST /api/assets – зарегистрировать актив
GET /api/assets/stats – статистика
GET /api/assets/non-compliant – некомплаентные активы
POST /api/assets/sync/mdm – синхронизировать из MDM
POST /api/assets/sync/scanner – синхронизировать из сканера
GET /api/assets/{asset_id} – актив по ID
PUT /api/assets/{asset_id} – обновить актив
GET /api/assets/{asset_id}/posture – compliance posture актива
GET /api/assets/{asset_id}/controls – контроли для актива

```

## Governance (P6)

```

GET /api/governance/posture – состояние governance
GET /api/governance/pending – pending approvals
POST /api/governance/attest – создать аттестацию
GET /api/governance/attestations/{control_id} – аттестации контроля
POST /api/governance/attest/{attestation_id}/revoke – отозвать аттестацию
GET /api/governance/can-approve?role=&action_type= – проверка прав
GET /api/governance/chain/{action_type} – цепочка одобрения

```

## Policy Lifecycle

```

GET /api/policies – список политик
GET /api/policies/summary – сводка по статусам
GET /api/policies/pending – ожидают одобрения

```

|                                 |                         |
|---------------------------------|-------------------------|
| GET /api/policies/{id}          | – политика по ID        |
| POST /api/policies/{id}/submit  | – отправить на проверку |
| POST /api/policies/{id}/approve | – одобрить              |
| POST /api/policies/{id}/reject  | – отклонить             |

## Risks

|                        |                     |
|------------------------|---------------------|
| GET /api/risks         | – список рисков     |
| GET /api/risks/summary | – сводка            |
| GET /api/risks/matrix  | – risk matrix (5×5) |
| POST /api/risks        | – создать риск      |
| PATCH /api/risks/{id}  | – обновить          |
| DELETE /api/risks/{id} | – удалить           |

## Vendors

|                          |                        |
|--------------------------|------------------------|
| GET /api/vendors         | – список вендоров      |
| GET /api/vendors/summary | – сводка по тирам      |
| POST /api/vendors/assess | – запустить assessment |
| GET /api/vendors/{id}    | – вендор по ID         |
| PATCH /api/vendors/{id}  | – обновить             |

## Полный список остальных API

|                          |                           |
|--------------------------|---------------------------|
| /api/access-review/*     | – access review workflow  |
| /api/auditor/*           | – аудиторский портал      |
| /api/training/*          | – обучение сотрудников    |
| /api/background-checks/* | – background checks       |
| /api/vulnerabilities/*   | – управление уязвимостями |
| /api/pentests/*          | – pentest management      |
| /api/questionnaires/*    | – vendor questionnaires   |
| /api/chaos/*             | – chaos engineering       |
| /api/control-mapping/*   | – фреймворк маппинг       |
| /api/time-machine/*      | – time machine (legacy)   |
| /api/cac/*               | – compliance as code      |
| /api/trust/*             | – trust center            |
| /api/gap-analysis/*      | – gap analysis            |
| /api/reports/*           | – отчёты                  |
| /api/decisions/*         | – AI decision log         |
| /api/engine/*            | – compliance engine       |
| /api/state/*             | – state engine            |
| /metrics                 | – Prometheus метрики      |

## 7. Установка и запуск

### Быстрый старт (dev-режим, LocalStack)

```
# 1. Клонировать и перейти в папку
cd /home/zastone/study/Poligon/sandbox-auditor

# 2. Создать виртуальное окружение
python3 -m venv venv
source venv/bin/activate

# 3. Установить зависимости
pip install -r requirements.txt

# 4. Скопировать конфиг
cp .env.example .env
# Отредактировать .env при необходимости
```

```
# 5. Поднять LocalStack и Redis
docker compose up -d localstack redis

# 6. Проинициализировать тестовую инфраструктуру AWS
python3 seed_infrastructure.py
python3 controls_seed.py

# 7. Запустить сервер
python3 ui_server.py
```

Открыть: `http://localhost:8080`  
Войти: `admin@example.com / admin123`

Полный Docker-стек

```
docker compose up -d

# Дождаться готовности
docker compose ps

# Проверить логи
docker compose logs -f ui_server
```

Проверка работоспособности

```
# Health check
curl http://localhost:8080/health

# Список контролей
curl -b "access_token=<TOKEN>" http://localhost:8080/api/controls

# Compliance score
curl http://localhost:8080/api/engine/score
```

Запуск тестов

```
python3 -m pytest tests/ -v
# Ожидаемый результат: 770/770 passed
```

8. Конфигурация — все переменные окружения

Обязательные в production

| Переменная     | Описание                                | Пример                               |
|----------------|-----------------------------------------|--------------------------------------|
| JWT_SECRET_KEY | Секрет для подписи JWT. Сменить дефолт! | <code>openssl rand -hex 32</code>    |
| SECRET_KEY     | Секрет для HMAC-подписи аттестаций      | <code>openssl rand -hex 32</code>    |
| CORS_ORIGINS   | Разрешённые origins через запятую       | <code>https://app.company.com</code> |

Интеграции

| Переменная                | Описание                                 |
|---------------------------|------------------------------------------|
| GITHUB_TOKEN              | GitHub Personal Access Token             |
| GITHUB_REPO               | Репозиторий (owner/repo)                 |
| SLACK_WEBHOOK_URL         | URL для Slack уведомлений                |
| JIRA_URL                  | URL Jira (https://company.atlassian.net) |
| JIRA_USER                 | Email пользователя Jira                  |
| JIRA_API_TOKEN            | API token Jira                           |
| JIRA_PROJECT_KEY          | Ключ проекта (SOC, COMP, ...)            |
| DOCUSIGN_INTEGRATION_KEY  | DocuSign integration key                 |
| DOCUSIGN_ACCOUNT_ID       | DocuSign account ID                      |
| JAMF_URL                  | URL Jamf Pro сервера                     |
| JAMF_USER / JAMF_PASSWORD | Credentials Jamf Pro                     |
| INTUNE_TENANT_ID          | Azure tenant ID для Intune               |
| INTUNE_CLIENT_ID          | App registration client ID               |
| INTUNE_CLIENT_SECRET      | App registration secret                  |

AI

| Переменная      | Описание                           | Дефолт                              |
|-----------------|------------------------------------|-------------------------------------|
| OPENAI_API_KEY  | OpenAI или OpenRouter API key      | —                                   |
| OPENAI_BASE_URL | Base URL (поменять для OpenRouter) | https://api.openai.com/v1           |
| OPENAI_MODEL    | Модель для анализа                 | google/gemini-flash-1.5             |
| POLICY_MODEL    | Модель для генерации политик       | anthropic/claude-haiku-4-5-20251001 |

Инфраструктура

| Переменная           | Описание                               | Дефолт                              |
|----------------------|----------------------------------------|-------------------------------------|
| DATABASE_URL         | PostgreSQL URL. Если не задан — SQLite | sqlite+aiosqlite:///./compliance.db |
| REDIS_URL            | Redis URL                              | redis://localhost:6379/0            |
| EVIDENCE_TRACKER_URL | URL Evidence Tracker API               | http://localhost:8000               |
| LOCALSTACK_ENDPOINT  | LocalStack endpoint                    | http://localhost:4566               |

AWS (для LocalStack или реального AWS)

```
AWS_ACCESS_KEY_ID=test
AWS_SECRET_ACCESS_KEY=test
AWS_DEFAULT_REGION=us-east-1
LOCALSTACK_ENDPOINT=http://localhost:4566
```

## 9. Пользователи и роли

### Встроенные учётные записи (из auth.py)

| Email                | Пароль      | Роль     | Что может                         |
|----------------------|-------------|----------|-----------------------------------|
| admin@example.com    | admin123    | admin    | Всё                               |
| auditor@example.com  | auditor123  | auditor  | Читать, комментировать            |
| reviewer@example.com | reviewer123 | reviewer | Одобрять политики, access reviews |
| scanner@example.com  | scanner123  | scanner  | Только запуск сканеров            |

В production сменить все пароли через .env файл!

### Матрица прав доступа

| Действие               | admin                    | auditor                  | reviewer                 | scanner                  |
|------------------------|--------------------------|--------------------------|--------------------------|--------------------------|
| Просмотр dashboard     | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Запуск сканеров        | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Просмотр доказательств | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Одобрение политик      | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Background Checks      | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Audit Timeline         | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Pentest управление     | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Access Review          | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Chaos Engineering      | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| Config изменение       | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |

## 10. Агенты — как запускать и что делают

### Через UI (Dashboard)

1. Открыть `http://localhost:8080`
2. Раздел "Agents"
3. Нажать кнопку нужного агента
4. Результаты стримятся в реальном времени через SSE

### Через командную строку

```
# AWS Scanner (S3, IAM, EC2, CloudTrail)
python3 scanner.py
```

```
# GitHub Agent
python3 github_agent.py

# HR Agent (Okta + HR roster)
python3 hr_agent.py

# MDM Agent (Jamf / Intune)
python3 mdm_agent.py

# Policy Generator (AI-черновики)
python3 policy_agent.py --governance

# Prowler (160 SOC 2 проверок)
python3 prowler_runner.py

# Survey Agent (опросы сотрудников)
python3 survey_agent.py

# Полный аудит одной командой (все агенты + отчёт)
python3 audit_runner.py --parallel
```

## Через API

```
# Запустить агент и получать результаты через SSE
curl -N -b "access_token=TOKEN" \
  http://localhost:8080/api/run/scanner

# Celery async (для тяжёлых задач)
curl -X POST -b "access_token=TOKEN" \
  http://localhost:8080/api/tasks/run/scanner
```

## Расписание автозапуска

По умолчанию полный сканер запускается каждый день в 03:00 UTC. Изменить в `ui_server.py`:

```
CronTrigger(hour=3, minute=0)
```

## Агенты и их SOC 2 контроли

| Агент              | Контроли                                 | Примерное время       |
|--------------------|------------------------------------------|-----------------------|
| AWS Scanner        | CC6.1, CC6.6, CC6.7, CC7.2, CC3.1, CC3.2 | 5–15 сек (LocalStack) |
| Prowler            | Все CC + дополнительные                  | 2–5 мин               |
| GitHub             | CC8.1, CC3.4, CC6.8                      | 10–30 сек             |
| HR                 | CC6.2, CC1.4, CC1.3                      | 5–20 сек              |
| MDM                | CC6.6, CC6.7, CC6.8                      | 10–30 сек             |
| Policy Generator   | CC1.1–CC1.5, CC2.x, CC5.x                | 2–5 мин (AI)          |
| Survey             | CC1.4, CC2.2                             | 5–15 сек              |
| Audit Runner (все) | Все 33                                   | 5–6 мин (parallel)    |

## 11. Сравнение с Vanta

> Честная оценка. Что есть, чего нет, что лучше, что хуже.

Ключевые метрики

| Метрика        | Sandbox Auditor                                                          | Vanta                                  |
|----------------|--------------------------------------------------------------------------|----------------------------------------|
| SOC 2 контроли | 33/33 (100%)                                                             | 33/33 (100%)                           |
| Фреймворки     | SOC 2, ISO 27001, NIST CSF, CIS                                          | SOC 2, ISO 27001, HIPAA, GDPR, PCI DSS |
| Интеграции     | ~14 (AWS, GitHub, Okta, Jira, DocuSign, Jamf, Intune, Slack, Prowler...) | 200+ (полный каталог)                  |
| Multi-tenant   | ☐ (одна организация)                                                     | ☐ (MSP-режим)                          |
| Цена           | Open-source / self-hosted                                                | \$7 000-\$50 000/год                   |
| AI             | ☐ (advisory only, explainable)                                           | ☐ (automated evidence collection)      |
| SLA            | ☐ (per-control SLA из ontology)                                          | ☐                                      |

Функциональное сравнение

| Функция                 | Sandbox Auditor           | Vanta             | Примечание                 |
|-------------------------|---------------------------|-------------------|----------------------------|
| Автосбор доказательств  | ☐ ~14 интеграций          | ☐ 200+ интеграций | Vanta выигрывает по охвату |
| Dashboard compliance %  | ☐                         | ☐                 | Паритет                    |
| Risk Register           | ☐ Auto-create при FAIL    | ☐                 | Паритет                    |
| Policy Management       | ☐ Full lifecycle + AI gen | ☐ Templates       | Паритет                    |
| Access Reviews          | ☐                         | ☐                 | Паритет                    |
| Security Training       | ☐ Встроенная LMS          | ☐ (интеграция)    | Паритет                    |
| Background Checks       | ☐                         | ☐                 | Паритет                    |
| Vendor Risk             | ☐                         | ☐                 | Паритет                    |
| Pentest Management      | ☐                         | ☐                 | Паритет                    |
| Trust Center            | ☐                         | ☐                 | Паритет                    |
| Auditor Portal          | ☐                         | ☐                 | Паритет                    |
| Questionnaires          | ☐ SIG Lite, CAIQ          | ☐                 | Паритет                    |
| Vulnerability Mgmt      | ☐ CVE + SLA               | ☐                 | Паритет                    |
| E-signature             | ☐ DocuSign                | ☐                 | Паритет                    |
| Webhook real-time       | ☐ GitHub, Okta, Slack     | ☐                 | Паритет                    |
| Reporting               | ☐ HTML + PDF              | ☐                 | Паритет                    |
| Multi-framework mapping | ☐ SOC2↔ISO↔NIST↔CIS       | ☐                 | Паритет                    |
| Compliance as Code      | ☐ YAML DSL + CI/CD        | ⚠ Частично        | Sandbox выигрывает         |
| Time Machine Audit      | ☐ Любая дата истории      | ☐ Нет             | Уникальная фича            |
| Event Sourcing + Replay | ☐ Детерминистичный replay | ☐ Нет             | Уникальная фича            |
| Compliance Graph        | ☐ Risk propagation, BFS   | ☐ Нет             | Уникальная фича            |

| Функция                  | Sandbox Auditor          | Vanta                  | Примечание         |
|--------------------------|--------------------------|------------------------|--------------------|
| AI Explainability        | ☐ Полный audit trail AI  | ⚠ Минимально           | Sandbox выигрывает |
| Deterministic Engine     | ☐ AI Advisory Only       | ⚠ AI принимает решения | Sandbox выигрывает |
| Chaos Engineering        | ☐ Inject + SLA measure   | ☐ Нет                  | Уникальная фиша    |
| Governance Graph         | ☐ HMAC attestations      | ⚠ Basic approvals      | Sandbox выигрывает |
| Asset-centric compliance | ☐ Per-asset posture      | ☐                      | Паритет            |
| Evidence Confidence      | ☐ Per-evidence scoring   | ☐ Нет                  | Sandbox выигрывает |
| State Engine             | ☐ Единый источник истины | ☐ Распределённый       | Sandbox выигрывает |
| SOAR (Slack actions)     | ☐ Revoke IAM из Slack    | ⚠ Частично             | Sandbox выигрывает |
| Prometheus + Grafana     | ☐                        | ☐ (отдельно)           | Паритет            |
| Multi-tenant             | ☐                        | ☐                      | Vanta выигрывает   |
| GCP / Azure сканеры      | ☐                        | ☐                      | Vanta выигрывает   |
| HIPAA / GDPR / PCI DSS   | ⚠ Custom controls        | ☐ Native               | Vanta выигрывает   |
| Managed service (SaaS)   | ☐ Self-hosted            | ☐                      | Vanta выигрывает   |
| Mobile app               | ☐                        | ☐                      | —                  |
| 200+ интеграций          | ☐ ~14                    | ☐                      | Vanta выигрывает   |
| Цена                     | Бесплатно                | \$7-50K/год            | Sandbox выигрывает |

## Архитектурное сравнение

| Аспект                         | Sandbox Auditor              | Vanta                  | Оценка                                    |
|--------------------------------|------------------------------|------------------------|-------------------------------------------|
| AI как советник (не авторитет) | ☐ Явно разделено             | ☐ AI принимает решения | Sandbox лучше для regulated industries    |
| Event sourcing                 | ☐ Полный                     | ☐                      | Sandbox лучше для audit defensibility     |
| Explainability                 | ☐ Каждое AI-решение записано | ⚠ Минимально           | Sandbox лучше                             |
| Compliance Graph               | ☐ Risk propagation           | ☐                      | Sandbox лучше                             |
| Открытый код                   | ☐                            | ☐ Закрытый             | Sandbox лучше для самостоятельного аудита |
| Enterprise scale               | ⚠ Одна организация           | ☐                      | Vanta лучше                               |
| Установка                      | 5 минут (Docker)             | Managed SaaS           | Зависит от предпочтений                   |

## Честный вывод

Где Sandbox Auditor превосходит Vanta:

- Глубина архитектуры (event sourcing, compliance graph, state engine)
- Прозрачность AI-решений (все действия AI записаны, explainable)
- Time Machine — уникальная функция для ретроспективных аудитов
- Chaos Engineering — нет аналогов на рынке

- Стоимость: \$0 против \$7 000–50 000/год
- Полный контроль над данными (self-hosted)

Где Vanta превосходит Sandbox Auditor:

- 200+ готовых интеграций (Sandbox: ~14)
- Multi-tenant (несколько организаций)
- GCP и Azure сканеры
- Native HIPAA, GDPR, PCI DSS
- Managed SaaS (не нужно администрировать)
- Enterprise customer support

Для кого Sandbox Auditor:

- Стартапы с техкомандой, которым нужен SOC 2 без \$50K/год
- Компании в regulated industries (финтех, healthtech), где важна explainability AI
- Команды, которым нужна максимальная гибкость и кастомизация
- R&D и исследовательские проекты

## 12. Мониторинг и алерты

### Grafana (<http://localhost:3000>)

Логин: `admin` / `soc2admin`

Дашборд "SOC 2 Compliance Dashboard" содержит 9 панелей:

| Панель            | Метрика              | SOC 2 контроль |
|-------------------|----------------------|----------------|
| Request Rate      | Запросов в секунду   | —              |
| Error Rate        | % ошибок 5xx         | CC7.1          |
| P95 Latency       | Задержка ответа      | CC7.1          |
| HTTP by Status    | 2xx/4xx/5xx timeline | CC7.2          |
| Latency Histogram | p50/p90/p99          | CC7.1          |
| Top Endpoints     | Таблица запросов     | —              |
| Auth Failures     | 401/403 по времени   | CC6.1          |
| Scan Activity     | Запуски сканеров     | CC7.2          |
| Compliance Score  | % от всего           | CC3.2          |

### Prometheus (<http://localhost:9090>)

Ключевые метрики:

```
http_requests_total{method, endpoint, status}
http_request_duration_seconds{endpoint}
```

### Slack-алерты

Система автоматически отправляет в Slack при:

- Контроль перешёл в FAIL (если severity = critical)
- SLA истёк для evidence

- Попытка несанкционированного доступа
- Риск эскалирован из MEDIUM в HIGH/CRITICAL

Настройка:

```
SLACK_WEBHOOK_URL=https://hooks.slack.com/services/...
```

## 13. База данных и хранение данных

### Режимы работы

Dev (SQLite):

```
compliance.db – основная база
data/event_store.json – события
data/governance.json – аттестации
data/assets.json – активы (fallback)
data/vendors.json – вендоры
data/risk_register.json – риски
data/policies.json – политики
controls_map.json – статусы контролей
```

Production (PostgreSQL):

```
DATABASE_URL=postgresql+asyncpg://user:pass@host:5432/compliance_db
```

При наличии `DATABASE_URL` все данные хранятся в PostgreSQL. JSON-файлы используются только как fallback.

### Таблицы базы данных

| Таблица             | Назначение                        |
|---------------------|-----------------------------------|
| evidence            | Доказательства с confidence score |
| control_status      | Текущий статус каждого контроля   |
| risk_entry          | Реестр рисков                     |
| vendor              | Вендоры третьих сторон            |
| policy_draft        | Черновики политик                 |
| training_completion | Факты прохождения обучения        |
| audit_event         | Immutable audit log (append-only) |

### Миграции

```
# Мигрировать из JSON в PostgreSQL
python3 db_migration.py

# Dry-run (без записи)
python3 db_migration.py --dry-run

# Только определённые сущности
python3 db_migration.py --only evidence,risks
```

## 14. Интеграции с внешними системами

### AWS / LocalStack

```
AWS_ACCESS_KEY_ID=test
AWS_SECRET_ACCESS_KEY=test
AWS_DEFAULT_REGION=us-east-1
LOCALSTACK_ENDPOINT=http://localhost:4566 # убрать в production
```

LocalStack эмулирует: S3, IAM, EC2, RDS, CloudTrail, STS, KMS.

### GitHub

```
GITHUB_TOKEN=ghp_...
GITHUB_REPO=owner/repo
```

Требуемые права токена: `repo`, `security_events`, `read:org`.

### Okta

Настраивается в `hr_agent.py`. Использует Okta API v1.

### Jira

```
JIRA_URL=https://company.atlassian.net
JIRA_USER=email@company.com
JIRA_API_TOKEN=...
JIRA_PROJECT_KEY=SOC
```

### DocuSign

```
DOCUSIGN_INTEGRATION_KEY=...
DOCUSIGN_SECRET_KEY=...
DOCUSIGN_ACCOUNT_ID=...
DOCUSIGN_BASE_URL=https://demo.docusign.net # demo или production
```

### Slack

```
SLACK_WEBHOOK_URL=https://hooks.slack.com/services/T.../B.../...
```

Для Slack-кнопок (SOAR) нужно также настроить `slack_actions_handler.py` и добавить `/webhooks/slack` как Interactivity URL в Slack App.

### Jamf Pro

```
JAMF_URL=https://company.jamfcloud.com
JAMF_USER=api_user
JAMF_PASSWORD=...
```

### Microsoft Intune

```
INTUNE_TENANT_ID=...
INTUNE_CLIENT_ID=...
```

```
INTUNE_CLIENT_SECRET=...
```

---

## 15. Устранение неполадок

### Сервер не запускается

```
# Проверить порт занят
lsof -i :8080

# Проверить импорты
python3 -c "import ui_server"

# Проверить конфиг
python3 -c "from config import get_settings; print(get_settings())"
```

### Агент "завис" в статусе Running

Система имеет watchdog-таймер: через 5 минут зависший агент автоматически останавливается. Если этого не произошло:

```
# Проверить запущенные агенты
curl -b "access_token=TOKEN" http://localhost:8080/api/running

# Перезапустить сервер (убивает все агенты)
pkill -f ui_server.py
python3 ui_server.py
```

### Prowler не работает в Docker

Prowler должен запускаться локально (не в контейнере):

```
# Установить Prowler
pip install prowler

# Запустить напрямую
python3 prowler_runner.py
```

### База данных: ошибка "metadata is reserved"

Если встречается в старых версиях кода — это известная проблема SQLAlchemy. Исправлено: `metadata` переименован в `extra_data` с `column alias`.

### Тесты падают: "asyncio mode not set"

```
# Убедиться что pytest.ini содержит:
cat pytest.ini
# asyncio_mode = auto
```

### LocalStack: ошибки подключения

```
# Проверить что LocalStack запущен
docker compose ps localstack

# Перезапустить
```

```
docker compose restart localstack

# Проверить доступность
curl http://localhost:4566/_localstack/health
```

Grafana: нет данных на дашборде

```
# Убедиться что Prometheus скрейпит метрики
curl http://localhost:9090/targets

# Сгенерировать трафик
curl http://localhost:8080/health
curl http://localhost:8080/api/controls
```

Логи

```
# Логи всех Docker-сервисов
docker compose logs -f

# Только ui_server
docker compose logs -f ui_server

# Структурированные JSON-логи
docker compose logs ui_server | python3 -m json.tool
```

16. Глоссарий

| Термин                     | Объяснение                                                                                                                                |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| SOC 2                      | Service Organization Control 2 — стандарт безопасности для SaaS-компаний. Проверяет: безопасность, доступность, конфиденциальность данных |
| AICPA                      | American Institute of Certified Public Accountants — орган, выпустивший стандарт SOC 2                                                    |
| TSC 2017                   | Trust Services Criteria 2017 — конкретный набор из 33 контролей SOC 2                                                                     |
| Control                    | Контроль — конкретное требование безопасности. Например: CC6.1 = MFA обязательна                                                          |
| Evidence                   | Доказательство — данные подтверждающие что контроль выполняется. Например: список IAM пользователей с включённой MFA                      |
| PASS / FAIL / NEEDS_REVIEW | Статусы контроля: выполнен / нарушен / требует ручной проверки                                                                            |
| CISO                       | Chief Information Security Officer — директор по информационной безопасности                                                              |
| Compliance Officer         | Специалист по соответствию требованиям                                                                                                    |
| SoD                        | Segregation of Duties — разделение обязанностей. Нельзя одному человеку создать и одобрить одно решение                                   |
| SLA                        | Service Level Agreement — допустимый срок. В контексте: через сколько часов FAIL должен быть исправлен                                    |

| Термин            | Объяснение                                                                                                    |
|-------------------|---------------------------------------------------------------------------------------------------------------|
| DPA               | Data Processing Agreement — соглашение об обработке данных (GDPR)                                             |
| MDM               | Mobile Device Management — система управления устройствами (Jamf Pro, Intune)                                 |
| HMAC              | Hash-based Message Authentication Code — криптографическая подпись для верификации данных                     |
| Event Sourcing    | Паттерн хранения данных: все изменения хранятся как последовательность событий, а не только текущее состояние |
| Deterministic     | Детерминистический — одинаковые входные данные всегда дают одинаковый результат (в отличие от AI)             |
| BFS               | Breadth-First Search — обход графа в ширину. Используется для поиска затронутых контролей                     |
| Replay            | Воспроизведение истории событий для восстановления состояния системы на определённый момент                   |
| Attestation       | Аттестация — официальное подтверждение человеком что контроль выполнен, с криптографической подписью          |
| Chaos Engineering | Намеренное введение сбоев для проверки устойчивости системы реагирования                                      |
| Confidence Score  | Уверенность — число от 0 до 1 показывающее насколько надёжно доказательство                                   |
| Gap Analysis      | Анализ пробелов — что конкретно нужно сделать чтобы закрыть нарушения                                         |
| CVE               | Common Vulnerabilities and Exposures — база данных известных уязвимостей                                      |
| CVSS              | Common Vulnerability Scoring System — система оценки серьёзности уязвимостей (0-10)                           |
| Prowler           | Open-source инструмент для AWS security checks (160+ проверок)                                                |
| LocalStack        | Локальный эмулятор AWS для разработки и тестирования                                                          |
| Celery            | Система очередей задач для Python (асинхронный запуск долгих операций)                                        |
| Event Bus         | Внутренняя шина событий — механизм pub/sub для обмена сообщениями между модулями                              |
| Trust Center      | Публичная страница с информацией о безопасности компании для клиентов                                         |
| Audit Trail       | Audit trail — полная хронологическая история всех действий в системе                                          |